ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.09

Indicadores de cumplimiento y auditoría interna

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.09 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. Indicadores de cumplimiento y auditoría interna..... 3
H.1 Plantilla de indicador..... 3
H.2 Propuesta de auditoría interna simulada..... 5
Supuestos declarados en este entregable..... 6
Cómo se leen juntos los indicadores y la auditoría..... 6

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	viernes 6 de noviembre de 2026 (H4)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.09 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E09_Indicadores_Auditoria_Interna_<Equipo>.docx (o .pdf).

3. Indicadores de cumplimiento y auditoría interna

Ejemplo resuelto de cátedra · entrega: viernes 6 de noviembre de 2026 (H4).

H.1 Plantilla de indicador

Cada uno de los seis controles desarrollados en E.07 declara al menos un indicador con esta ficha; la fuente del dato es la evidencia que el SOP genera (F.3). El equipo copia la ficha H.1 una vez por indicador.

Campo	Contenido
Nombre del indicador	IND-01 · Cobertura de la segmentación entre la red de TI y la red OT
Fórmula	(Puntos de conexión TI–OT que atraviesan el punto de filtrado ÷ total de puntos de conexión identificados) × 100
Meta	100 %; umbral de alerta por debajo de 95 %
Frecuencia de medición	Mensual
Fuente del dato	Reporte trimestral de revisión de reglas y diagrama de arquitectura versionado del SOP del control 12
Responsable	Mide: analista de seguridad de TO. Recibe: Jefatura de Seguridad de la Información y Gerencia de Operaciones de Red

Los doce indicadores del programa se construyen con esta misma ficha; cada uno de los seis controles desarrollados en E.07 aporta dos, y todos se alimentan de la evidencia que genera su procedimiento operativo. Las metas se fijaron con el criterio de que el indicador sea alcanzable dentro del horizonte que el roadmap de E.10 declara para su control.

Indicador	Control	Fórmula	Meta y umbral de alerta	Frecuencia	Fuente del dato (evidencia del SOP)	Mide / recibe
IND-01 Cobertura de la segmentación TI–OT	12	Puntos de conexión filtrados ÷ puntos de conexión identificados × 100	100 % · alerta < 95 %	Mensual	Reporte de revisión de reglas y diagrama de arquitectura	Analista de TO / Jefatura de Seguridad y Operaciones de Red
IND-02 Reglas de filtrado revalidadas en el trimestre	12	Reglas revalidadas o retiradas ÷ reglas con más de doce meses × 100	100 % · alerta < 90 %	Trimestral	Reporte trimestral de revisión de reglas	Analista de TO / Jefatura de Seguridad
IND-03 Fuentes de eventos que reportan	13	Fuentes que reportaron en las últimas 24 h ÷ fuentes declaradas × 100	≥ 98 % · alerta < 95 %	Mensual	Inventario de fuentes con estado de reporte	Analista de seguridad de TI / Jefatura de Seguridad
IND-04 Atención de alertas de severidad alta dentro de la hora	13	Alertas altas atendidas en ≤ 60 min ÷ alertas altas × 100	≥ 95 % · alerta < 85 %	Mensual	Cola de alertas con clasificación y tiempos	Analista de TO / Jefatura de Seguridad
IND-05 Cuentas privilegiadas con segundo factor	6	Cuentas administrativas con MFA activo ÷ cuentas administrativas × 100	100 % · alerta < 100 %	Mensual	Inventario de cuentas privilegiadas	Administrador de identidades / Jefatura de Seguridad
IND-06 Sesiones de proveedor dentro de ventana autorizada	6	Sesiones con solicitud, ventana y grabación ÷ sesiones de proveedor × 100	100 % · alerta < 100 %	Mensual	Registro de sesiones del concentrador de acceso	Administrador de identidades / Jefatura de Seguridad y Gerencia General
IND-07 Vulnerabilidades críticas remediadas en plazo	7	Vulnerabilidades críticas cerradas en ≤ 15 días ÷ críticas detectadas × 100	≥ 95 % · alerta < 85 %	Mensual	Registro de hallazgos con responsable y plazo	Analista de seguridad de TI / Jefatura de Seguridad
IND-08 Activos del entorno OT con tratamiento decidido	7	Vulnerabilidades de OT con decisión registrada ÷ vulnerabilidades de OT detectadas × 100	100 % · alerta < 90 %	Trimestral	Actas de ventana de mantenimiento y registro de medidas compensatorias	Analista de TO / Jefatura de Seguridad y Operaciones de Red
IND-09 Respaldos exitosos de los sistemas críticos	11	Ciclos de respaldo exitosos ÷ ciclos programados × 100	≥ 99 % · alerta < 97 %	Mensual	Bitácora diaria de trabajos de respaldo	Administrador de plataformas / Jefatura de Seguridad
IND-10 Pruebas de restauración que alcanzan el RTO	11	Pruebas que restauran dentro del RTO ÷ pruebas ejecutadas × 100	100 % · alerta < 100 % en el entorno SCADA	Trimestral	Acta de prueba con tiempo medido y verificación funcional	Administrador de plataformas / Gerencia General

Indicador	Control	Fórmula	Meta y umbral de alerta	Frecuencia	Fuente del dato (evidencia del SOP)	Mide / recibe
IND-11 Proveedores críticos con anexo de seguridad vigente	15	Proveedores de nivel crítico con anexo firmado ÷ proveedores de nivel crítico × 100	100 % · alerta < 100 %	Semestral	Inventario de proveedores y contratos con anexo	Analista de cumplimiento / Jefatura de Seguridad
IND-12 Evidencia anual de controles recibida de proveedores críticos	15	Proveedores críticos con evidencia del año ÷ proveedores críticos × 100	≥ 90 % · alerta < 75 %	Anual	Registro de evidencia recibida y su evaluación	Analista de cumplimiento / Jefatura de Seguridad

Los indicadores IND-01, IND-05 e IND-10 miden de forma directa los objetivos O-2, O-3 y O-1 que la dirección declaró en E.02, de modo que la revisión trimestral por la dirección lee el avance del programa con las mismas palabras con que lo comprometió.

H.2 Propuesta de auditoría interna simulada

Fundamento: ISO/IEC 27001:2022, cláusula 9.2: la organización verifica con auditorías internas que su SGSI opera conforme a lo planificado. El equipo propone una auditoría con estos elementos:

Elemento	Contenido de la propuesta
Alcance y objetivo	Auditar los seis controles desarrollados —12, 13, 6, 7, 11 y 15— y los procesos P-01 y P-04 que sostienen. Objetivo: confirmar que las políticas y los procedimientos operan como están escritos y que la evidencia declarada existe, es completa y es verificable
Criterios	Las políticas y los procedimientos del propio proyecto; CIS Controls v8.1 (2024) en las salvaguardas de los seis controles; ISO/IEC 27001:2022 cláusulas 7.5 información documentada, 8 operación y 9 evaluación del desempeño; ISO/IEC 27002:2022 en los controles correspondientes; y la LPDP (D.L. 144/2024) en lo relativo a los datos de clientes
Método y muestra	Revisión documental de políticas y procedimientos; verificación de la evidencia que cada SOP genera; entrevistas simuladas con los ejecutores; y prueba de recorrido sobre dos controles. Muestra por control: 25 reglas de filtrado de un universo estimado de 180; 20 alertas de severidad alta del trimestre; 15 cuentas privilegiadas de un universo de 46; 20 hallazgos de vulnerabilidad de los últimos tres meses; las 4 pruebas de restauración del año; y los 6 proveedores de nivel crítico, en censo completo
Programa	Del 9 al 20 de marzo de 2027, con informe preliminar el 24 de marzo y final el 31. Auditor designado: analista de cumplimiento adscrito a Finanzas, independiente de la Jefatura de Seguridad y de TI/TO, con apoyo de un auditor externo para la parte de tecnología de operación. Duración estimada: diez días hábiles
Informe y hallazgos	Cada hallazgo se clasifica como conformidad, no conformidad mayor, no conformidad menor u oportunidad de mejora, con el criterio incumplido, la evidencia que lo sostiene y el riesgo de E.05 al que se asocia. El informe se dirige a la Gerencia General, con copia a la Jefatura de Seguridad y a los dueños de proceso auditados
Seguimiento	Cada no conformidad genera una acción correctiva con responsable, plazo y análisis de causa. Las acciones se revisan en la reunión trimestral de la dirección —el paso Actuar del ciclo PDCA — y las que exijan inversión o cambio de arquitectura se incorporan al roadmap de E.10 en su horizonte correspondiente. El cierre de cada acción se verifica con evidencia antes de darla por concluida

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
—	Sin supuestos nuevos en este entregable.	Los indicadores y la auditoría interna se construyen sobre los seis controles de E.07 y sobre los entregables anteriores.

Cómo se leen juntos los indicadores y la auditoría

Los indicadores miden el funcionamiento continuo y la auditoría verifica que lo medido es cierto. Tres indicadores del programa tienen meta del 100 % sin tolerancia —cuentas privilegiadas con segundo factor, sesiones de proveedor dentro de ventana y pruebas de restauración dentro del RTO— porque cada uno corresponde a un riesgo Crítico de la matriz de E.05: una sola excepción reabre la condición que hizo Crítico al riesgo. Los demás admiten umbral de alerta, que es el nivel en que la Jefatura de Seguridad interviene antes de que el incumplimiento se vuelva un hallazgo.